МИНИСТЕРСТВО НАУКИ И ВЫСШЕГО ОБРАЗОВАНИЯ РОССИЙСКОЙ ФЕДЕРАЦИИ
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
МОСКОВСКИЙ АВИАЦИОННЫЙ ИНСТИТУТ
(национальный исследовательский университет)

Выпускная квалификационная работа бакалавра

на тему: «Разработка открытого инструмента статического анализа PE файлов для выявления намеренных искажений структуры и заголовков»

Руководитель ВКР:
Маркин Алексей Леонидович

Студент группы М8О-413Б-23:
Колесник Дмитрий Сергеевич

Москва 2026

Актуальность темы и исследовательская база

- **Сбои анализаторов на нестандартных файлах**

  Исследования методологии LangSec подтверждают: различие в интерпретации деформированных бинарных заголовков между строгими анализаторами и загрузчиком ОС порождает критические уязвимости обхода защиты

  (Sean W. Smith, Sameed Ali: «A Survey of Parser Differential Anti-Patterns»)

- **Практика атак и сокрытия полезной нагрузки:**

  Манипуляции со структурами PE (фальсификация Rich Header, аномалии прав секций W+X, оверлеи) активно применяются для маскировки кода и вывода из строя статических сканеров без запуска в песочнице.

  (Mitre ATTACK: "Obfuscated Files or Information")

- **Последствия:**

  - Вредоносный файл с измененной структурой может пройти «мимо» системы проверки, но успешно запуститься на компьютере жертвы;
  - Файлы придется либо разбирать вручную, либо в большом количестве отправлять в «песочницу» или дизассемблер, что может быть долгим или накладным по ресурсам;
  - Намеренно поврежденный файл может вызвать ошибку памяти, зависание или падение анализатора и системы

Проблемы существующих решений

Класс и представители	В чём проблема / на чём валятся	Требование к решению (ТЗ)
Коммерческие продукты (pestudio Pro, Enterprise SDK)	Закрытый код («чёрный ящик»), консоль и JSON заблокированы платной лицензией, привязка к облакам.	Полностью открытое ПО (Open Source), локальная автономная работа без подписок и внешних серверов.
Сырые парсеры (pefile, LIEF)	Аварийно падают на повреждённых заголовках (PEFormatError); нет готовой аналитики и вердиктов.	Собственный устойчивый парсер с контролем границ памяти и готовыми алгоритмами детекции.
Сигнатурные сканеры (Detect It Easy)	Ищут только байтовые паттерны упаковщиков; не ловят аномалии структуры и трюки обхода.	Алгоритмический аудит структуры (права W+X, оверлеи, Rich Header, энтропия).
Утилиты ручного разбора (PE-bear, Manalyze)	Только ручной графический интерфейс (PE-bear) либо заброшенная база эвристик (Manalyze).	Консольный CLI и библиотека (DLL / .so) с нативной выгрузкой отчёта в структурированный JSON.
Песочницы и дизассемблеры (Mandiant capa, CAPE Sandbox)	Глубокий анализ занимает десятки секунд и минуты, перегружая очереди поточной обработки.	Экспресс-отсев за миллисекунды на уровне заголовков без эмуляции и дизассемблирования.

Цель и задачи работы

Цель: Повышение полноты выявления структурных аномалий при обеспечении отказоустойчивости первичного статического анализа PE-файлов с учётом особенностей загрузчика Windows за счёт разработки программного обеспечения экспресс-контроля

1	Спроектировать архитектуру инструмента и систематизировать техники обхода статического анализа с учётом поведения загрузчика Windows
2	Разработать собственный устойчивый парсер заголовков с контролем границ памяти.
3	Разработать алгоритмы детекции аномалий: модификаций заголовков, секций W+X, скрытых оверлеев, подделки Rich Header и энтропии секций.
4	Программно реализовать аналитическое ядро (разделяемую библиотеку DLL/.so) и консольную утилиту (CLI) с выводом отчёта в JSON.
5	Провести тестирование на системных файлах и открытом корпусе Corkami, выполнив сравнение с существующими аналогами.

Бизнес-задачи

- **Снижение нагрузки на инфраструктуру:**

  Быстрый отсев файлов за миллисекунды, чтобы не перегружать медленные и дорогие песочницы потоком обычных данных.

- **Защита конвейера от сбоев:**

  Предотвращение зависаний и аварийных падений автоматических очередей при разборе намеренно повреждённых файлов.

- **Раннее выявление скрытых угроз:**

  Обнаружение признаков сокрытия кода (оверлеи, модификации заголовков, подозрительные секции) до запуска программы

- **Автономность и безопасность:**

  Работа в закрытом контуре без передачи данных во внешние облака и без привязки к платным зарубежным лицензиям.

АРХИТЕКТУРА ПРОГРАММНОГО ОБЕСПЕЧЕНИЯ

СЦЕНАРИИ ПРИМЕНЕНИЯ (ВНЕШНИЙ КОНТЕКСТ)



Серверный конвейер (Pre-filtering)

Автоматическая экспресс-сортировка входящего потока файлов перед передачей в тяжелую песочницу



Изолированный локальный стенд

Быстрая ручная или пакетная проверка подозрительных образцов аналитиком на закрытой машине без сети

Вызов / Запуск

Вызов / Запуск

ИНТЕРФЕЙСНЫЙ СЛОЙ ИНТЕГРАЦИИ



Консольная утилита (CLI)

Автономный исполняемый файл для работы в консоли и bash/powershell-скриптах



Разделяемая библиотека (DLL / .so)

Программный интерфейс для встраивания в сторонние сервисы (C++, Python, Go) на Windows и Linux

Передача буфера файла

АВТОНОМНОЕ АНАЛИТИЧЕСКОЕ ЯДРО (C++ / RUST)



Безопасный парсер

Разбор DOS/NT заголовков и таблиц секций с контролем границ буфера (Bounds Checking)



Детектор аномалий

Выявление модификаций заголовков, секций W+X, скрытых оверлеев и подделки Rich Header



Модуль энтропии

Расчет энтропии по секциям файла для обнаружения упакованных или зашифрованных участков



Генератор отчетов

Сбор вердикта, оценка уровня риска и сериализация итогового JSON-отчета

Встраивается как легковесный автономный фильтр первого эшелона без внешних зависимостей

Стек технологий и методика тестирования

- **Стек:**
  - **Ядро и безопасный парсер (C++20 / Rust):** Строгий контроль границ буфера при чтении бинарных структур (std::span в C++ или слайсы и модель владения в Rust) для исключения падений по ошибкам доступа к памяти (Out-of-Bounds / Segmentation Fault);
  - **Интерфейсный уровень:** разделяемая библиотека (DLL / .so) и консольная утилита (CLI) — полностью автономная работа без сторонних зависимостей и без доступа в сеть;
  - **Формат вывода:** JSON-отчёт — список найденных аномалий и итоговая оценка риска для интеграции в конвейеры.

- **Тестирование:**
  - **Тестовые датасеты:** Системные файлы чистой ОС Windows (контроль ложных срабатываний) и открытый корпус Corkami (стресс-тест на файлах с намеренно деформированной структурой);
  - **Инструменты для сравнения: Метрик**Библиотека pefile, статический анализатор Manalyze, консольный сканер Detect It Easy (diec);
  - **и эффективности:** Устойчивость к аномалиям (процент аварийных падений парсера) и скорость обработки (мс на файл / МБ в секунду).

Результаты

- **Устойчивость к битым заголовкам:**
  - **Было:** Стандартные парсеры (например, pefile) аварийно падают с ошибкой и ломают конвейер.
  - **Стало:** Безопасный разбор без падений: вместо вылета программа выдаёт отчёт о найденных аномалиях.

- **Применимость для автоматизации:**
  - **Было:** Утилиты работают только через графическое окно (PE-bear) либо требуют платную лицензию за консоль (pestudio).
  - **Стало:** Открытая консольная утилита (CLI) и библиотека (DLL / .so) с прямым выводом в JSON.

- **Скорость и нагрузка на систему:**
  - **Было:** Глубокая проверка в песочницах и дизассемблерах занимает десятки секунд на каждый файл.
  - **Стало:** Экспресс-проверка структуры и энтропии за доли секунды без запуска бинарника.

Github-репозиторий:
https://github.com/DmitriyKolesnikM8O/diplom

